

Identificazione di una scansione Nmap

1. Sintesi

Il presente documento descrive l'analisi di una cattura di traffico di rete in formato pcapng fornita in un ambito di laboratorio del corso Epicode.

1.1 Obiettivo

L'obiettivo è identificare il traffico osservato su Wireshark per riconoscere cosa l'attaccante ha utilizzato e per determinare quali servizi del sistema target risultano esposti.

L'analisi che ho effettuato conferma una scansione delle porte effettuata con Nmap, in modalità TCP Connect, verso un target che ha le caratteristiche di una macchina/sistema vulnerabile utilizzato anch'esso a scopo didattico.

2. Introduzione

Saper leggere le catture di traffico di rete sono le fondamenta per chi lavora in ambito difensivo. Permettono di poter ricostruire cos'è successo su una parte di rete e di differenziare il traffico legittimo da quello potenzialmente malevolo.

In questo lab ho lavorato con il file pcapng su Wireshark ed ho ricostruito le azioni dell'attaccante a partire dai pacchetti scambiati.

3. Panoramica della Cattura

3.1 Dati Generali

Il file analizzato contiene 2.083 pacchetti raccolti in circa 37 secondi.

Viene utilizzato maggiormente il protocollo TCP, con una presenza di ARP e un singolo pacchetto UDP di broadcast NetBIOS.

Il numero elevato di pacchetti in così poco tempo fa capire subito che non si tratta di traffico di una normale attività da parte di un utente.

3.2 Host Coinvolti

Sono presenti soltanto due indirizzi IP:

- 192.168.200.100: host che fa quasi tutte le richieste e che svolge il ruolo di attaccante.
- 192.168.200.150: host destinatario delle richieste e quindi rappresenta il sistema target.

Entrambi appartengono alla stessa sottorete privata, quindi da qui capiamo che si tratta di uno scenario di laboratorio eseguito in un ambiente virtualizzato.

4. Analisi del Comportamento dell'Attaccante

4.1 Tipologia di traffico generato

Scorrendo la cattura in Wireshark, ho notato che l'host 192.168.200.100 invia un grandissimo numero di pacchetti con il solo flag SYN attivo, diretti verso porte sempre diverse del target (la porta di destinazione aumenta progressivamente da 1 fino a 1024).

Questo comportamento, un host che bussa a tante porte diverse in pochi secondi, corrisponde a un'attività di port scanning, normalmente eseguita con lo strumento Nmap.

4.2 Riconoscimento del Tipo di Scansione

Inizialmente avevo ipotizzato una SYN scan (opzione **-sS**), che rappresenta la modalità più studiata in aula. Però analizzando la sequenza di pacchetti scambiati su una porta aperta, ad esempio la 22(SSH), ho osservato il seguente schema:

- Attaccante invia SYN al target;
- Target risponde con SYN-ACK, il che fa capire che c'è la porta aperta;
- Attaccante invia ACK, e così si completa l'handshake a tre vie;
- Attaccante subito dopo invia RST per chiudere la connessione.

La presenza del pacchetto ACK in mezzo alla sequenza esclude la SYN scan, nella quale Nmap interrompe l'handshake prima della sua conclusione.

Si tratta quindi di una TCP Connect scan (opzione **-sT**), modalità che richiede il completamento dell'handshake e risulta pertanto più rumorosa, poiché lascia traccia anche nei log applicativi del sistema target.

4.3 Tempistiche

I 1024 pacchetti SYN sono stati inviati in circa 13 secondi, con una media di circa 78 pacchetti al secondo.

Deduco dunque da questo ritmo elevato, l'uso dell'opzione **-T4** di nmap.

4.4 Verifica dell'intervallo di porte scansionato

Per capire se fosse stata eseguita una scansione limitata, ho utilizzato dei filtri su Wireshark per isolare i pacchetti SYN al target e vedere le porte di destinazione.

Il risultato mi ha mostrato 1024 porte diverse, in sequenza dalla 1 alla 1024.

Questo esclude sia la scansione default di Nmap (ovvero le prime 1000 porte sparse) sia una scansione completa **-p-** sulle 65535. Da qui si evince l'uso di nmap **-p 1-1024**.

5. Servizi esposti sul sistema target.

Per identificare le porte aperte ho cercato nella cattura di Wireshark le risposte del target: ogni volta che 192.168.200.150 risponde con SYN-ACK significa che la porta accetta ed è quindi aperta.

Le altre porte rifiutate rispondono con RST-ACK.

In totale risultano 12 servizi attivi:

Porte	Servizio
• 21	FTP
• 22	SSH
• 23	TELNET
• 25	SMTP
• 53	DNS
• 80	HTTP
• 111	RPCbind/Portmapper
• 139	NetBIOS Session Service
• 445	SMB (Samba)
• 512,513,514	Servizi legacy r-exec, rlogin, rsh

Questo insieme di servizi molto vecchi come Telnet, mi portano alla conclusione che sia la configurazione base di Metasploitable 2. Essa è una macchina vulnerabile intenzionalmente per scopi didattici.

Quindi si può constatare che la cattura di Wireshark è una sessione di laboratorio e non un attacco reale.

6. Considerazioni dal lato difensivo

L'esercizio mi ha aiutato a fissare alcuni concetti soprattutto in ottica SOC:

- La scansione completa delle prime 1024 porte in pochi secondi da un singolo host. Facile da rilevare attraverso regole.
- La TCP Connect Scan, che completando l'handshake, risulta visibile non solo alla rete ma anche ai servizi per esempio SSH che registra subito tentativi di connessione per poi chiuderli subito.
- La cattura non contiene una scansione sul tipo di servizio: un attaccante reale avrebbe sicuramente effettuato una scansione di tipo **-sV** per identificare le versioni dei servizi per poi cercare exploit specifici.

7. Conclusioni

Grazie a questa analisi ho capito che il traffico osservato era una scansione di ricognizione fatta con Nmap in modalità TCP Connect, contro un sistema che sembra essere Metasploitable 2.

La parte più difficile è stata capire di che tipo di scansione si trattasse, perché per riconoscerla bisognava guardare bene i flag dei pacchetti TCP.

Con questo esercizio ho imparato a leggere meglio la handshake TCP attraverso i flag **SYN**, **ACK** e **RST** e ad usare i filtri di Wireshark per trovare velocemente le porte aperte di un sistema.